

[Student Copy]

Lab: Familiarization with Vulnerability Scanning using `Nessus` and `nmap`

OBJECTIVES:

After this lab activity, student will be able to:

1. Scan for vulnerability using `Nessus`
2. Scan for vulnerability using `nmap`
3. Find more information related to Common Vulnerabilities and Exposures (CVE)

Zero Etical Hacking (ZEH) Pentest Methodology	Comments
Phase 1: Reconnaissance	
Phase 2: Scanning	
Port Scanning	
Vulnerability Scanning	Nessus and Nmap can be used for vulnerability scanning.
Phase 3: Exploit	
Phase 4: Post Exploit & Maintaining Access	

INTRODUCTION:

In this exercise, use `Nessus` in `Kali Linux` (pentestVM) to scan `Windows XP` (targetVM)
 (Can refer to YouTube: <https://www.youtube.com/watch?v=T4JT8osxbg>)

LAB ACTIVITY:

You are to do the lab activity using `Nessus` as stated in the following steps:
 (Can refer to YouTube: <https://www.youtube.com/watch?v=T4JT8osxbg>)

ACTIVITY 1: Vulnerability Scanning using Nessus

Follow the steps given below:

STEP	VM	DESCRIPTION
1	pentestVM	Set your pentestVM to use HOST-ONLY network adapter.
2	pentestVM	Open (power on) your pentestVM.
3	pentestVM	Open web browser.
4	pentestVM	Download Nessus.
5	pentestVM	Install Nessus. #cd downloads #sudo dpkg -i Nessus-10.8.4-ubuntu1604_amd64.deb
6	pentestVM	Start nessus service #/bin/systemctl start nessusd.service
7	pentestVM	Open nessus in web browser https://kali:8834
8	targetVM	Set your targetVM to use HOST-ONLY network adapter.
9	targetVM	Open (power on) your targetVM.
10		Get IP address of targetVM. Open DOS prompt and type: C:\>ipconfig

11	pentestVM	Conduct a vulnerability scanning. - Click on "New Scan" button - Use your targetVM IP address for scanning - Name your scan as scanTargetVM - Refer to FIGURE A1 in APPENDIX
12	pentestVM	Jot down Vulnerability information (e.g. CVSS ranking, CVE id), to be exploited (using Metasploit ONLY) for the next pentest phase (exploit phase). Refer to FIGURE A2-A6 in APPENDIX.
13	pentestVM	Stop nessus service <code>#/bin/systemctl start nessusd.service</code>

ACTIVITY 2: Vulnerability Scanning using nmap

Run vulnerability scanning using nmap script, assuming the target IP address is 192.168.201.132.
`#nmap -sC -sV -p- -iL 192.168.201.132`

ACTIVITY 3: Get CVE information from Metasploit

Many Metasploit modules include a References section in their metadata, which lists associated CVE IDs. For instance, you can view the CVE id for **ms08_067_netapi** exploit by running this command in Metasploit:

NOTE: Type the command **msfconsole** to get into Metasploit.

```
msf > info exploit/windows/smb/ms08_067_netapi
```

```
.....
'References' => [
  ['CVE', '2008-4250'],
  ['MSB', 'MS08-067'],
  ['BID', '30310']
]
```

```
.....
(type 'exit' to quit from Metasploit)
```

NOTE: Now we know that the CVE id for **exploit/windows/smb/ms08_067_netapi** exploit is **'2008-4250'**.

ACTIVITY 4: Get CVE information from online sources

1. nvd.nist.gov

To get information of CVE id 2008-4250 (for windows XP), type the URL as the following:
<https://nvd.nist.gov/vuln/detail/CVE-2008-4250>
 (Refer to FIGURE A6 to FIGURE A7)

NOTE:

To view the next CVE id (e.g 2009-1377), just type the URL as follows:
<https://nvd.nist.gov/vuln/detail/CVE-2008-4250>

2. exploit-db.com

To get information of **CVE id 2008-4250** (for windows XP), go to **exploit-db.com** (Refer to **FIGURE A8** to **FIGURE A9**)

QUESTIONS

1. List 5 commercial tools and 5 free tools that can be used for vulnerability scanning other than Nessus. (2 marks)
2. Briefly discuss on the difference between a commercial and a non-commercial version of Nessus? (2 marks)
3. How Nessus rank vulnerabilities? (2 marks)
4. Compare between CVSSv2 and CVSSv3. (2 marks)
5. Find CVE id for *syncbreeze* exploit. (2 marks)
6. List 10 available CVE for Windows XP, and sort them according to criticality based on CVSS ranking. (5 marks)
7. Assume that 2 different CVE with CVSS score of 9 (CVE1) and the other with CVSS score of 3 (CVE2) are found after scanning with Nessus. Which should be chosen for EXPLOITATION? Discuss. (5 marks)
8. Record a short video for scanning targetVM from pentestVM. (10 marks)
9. Record a short video for finding CVE for Windows XP that can be used with Metasploit from exploit-db.com. (10 marks)
10. Record a short video for finding CVE for other older Windows (other than Windows XP) that can be used with Metasploit from nvd.nist.gov. (5 marks)
11. Run vulnerability scanning on targetVM using nmap.
 - a. Write the nmap command for this scan. (2 marks)
 - b. Capture complete output of the scan. (3 marks)

APPENDIX

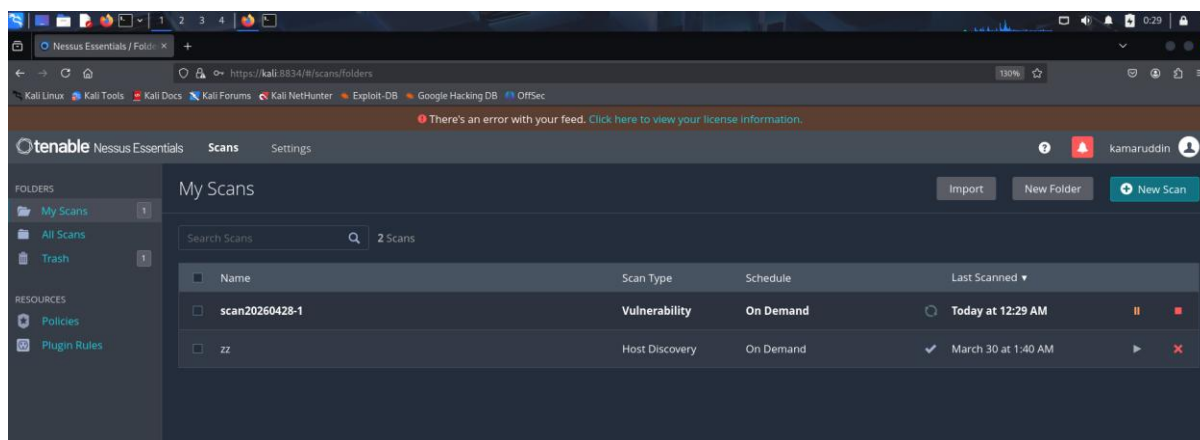


FIGURE A1: Create a new scan by clicking on “New Scan” button on the top right corner. Click on your scan result. You will get screen as shown in FIGURE A2.

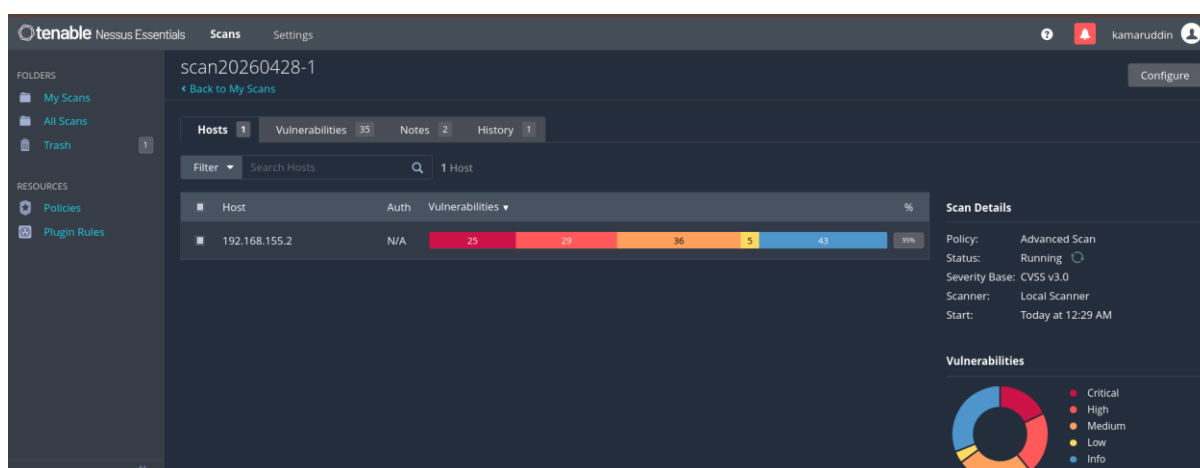


FIGURE A2: This is the result of the scan. Click on the Vulnerabilities (e.g. on the RED box@CRITICAL) to view details.

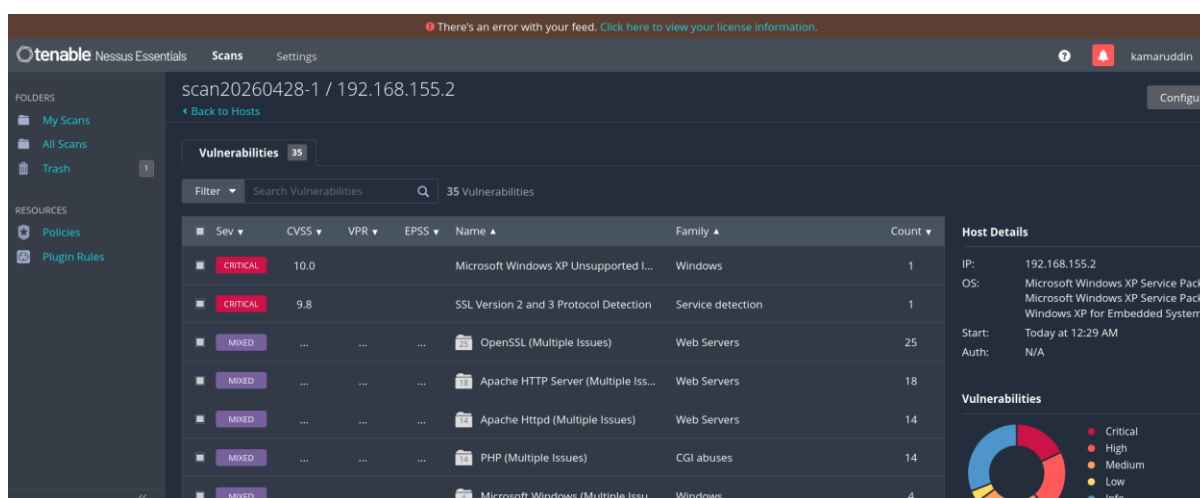


FIGURE A3: Details of vulnerabilities. Look for vulnerabilities with higher CVSS ranking values. CVSS values are between 0-10. CVSS value of 10 is the most CRITICAL, and most vulnerable for attack.

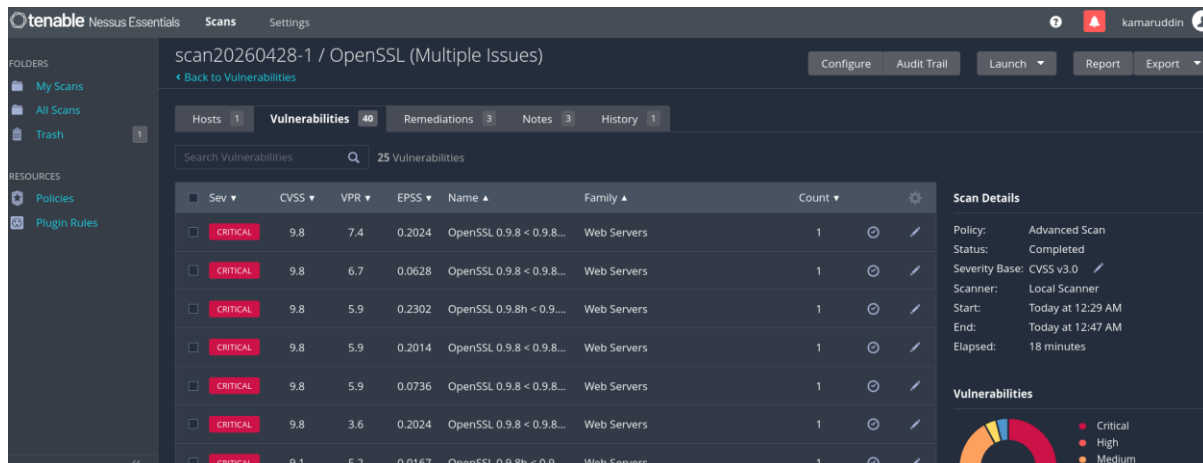


FIGURE A4: Details of vulnerabilities. Click on one of the vulnerabilities for details.

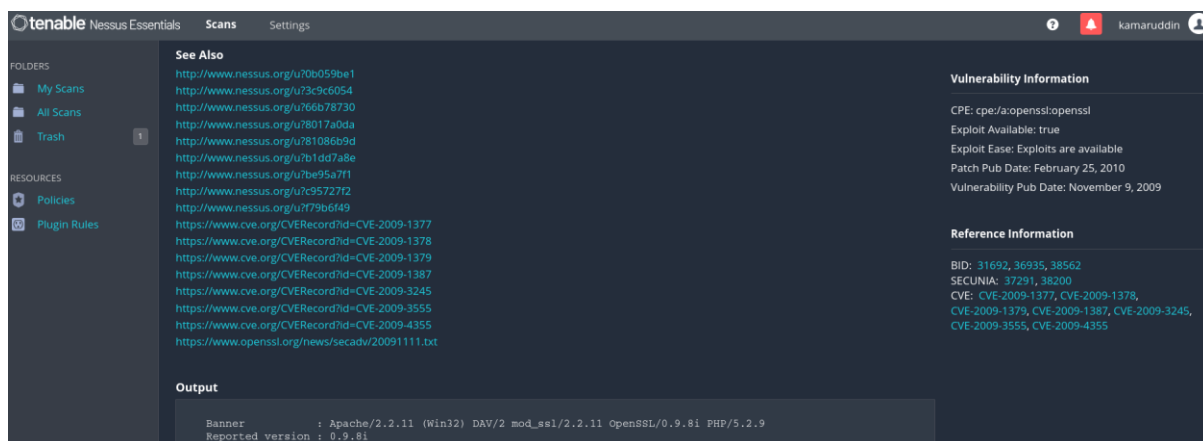


FIGURE A5: Show details of chosen vulnerability with CVE id information.

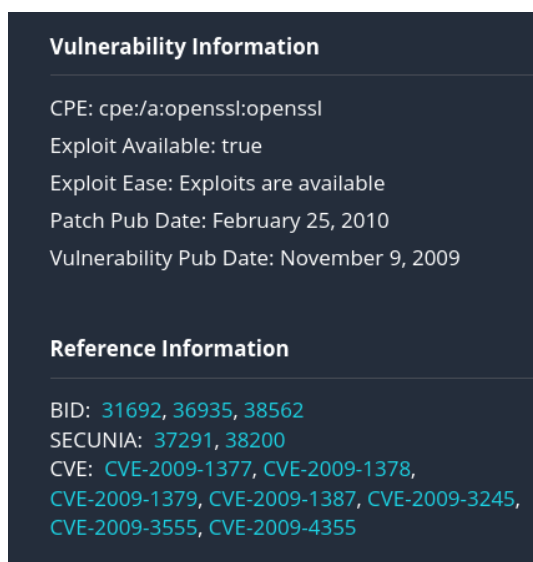
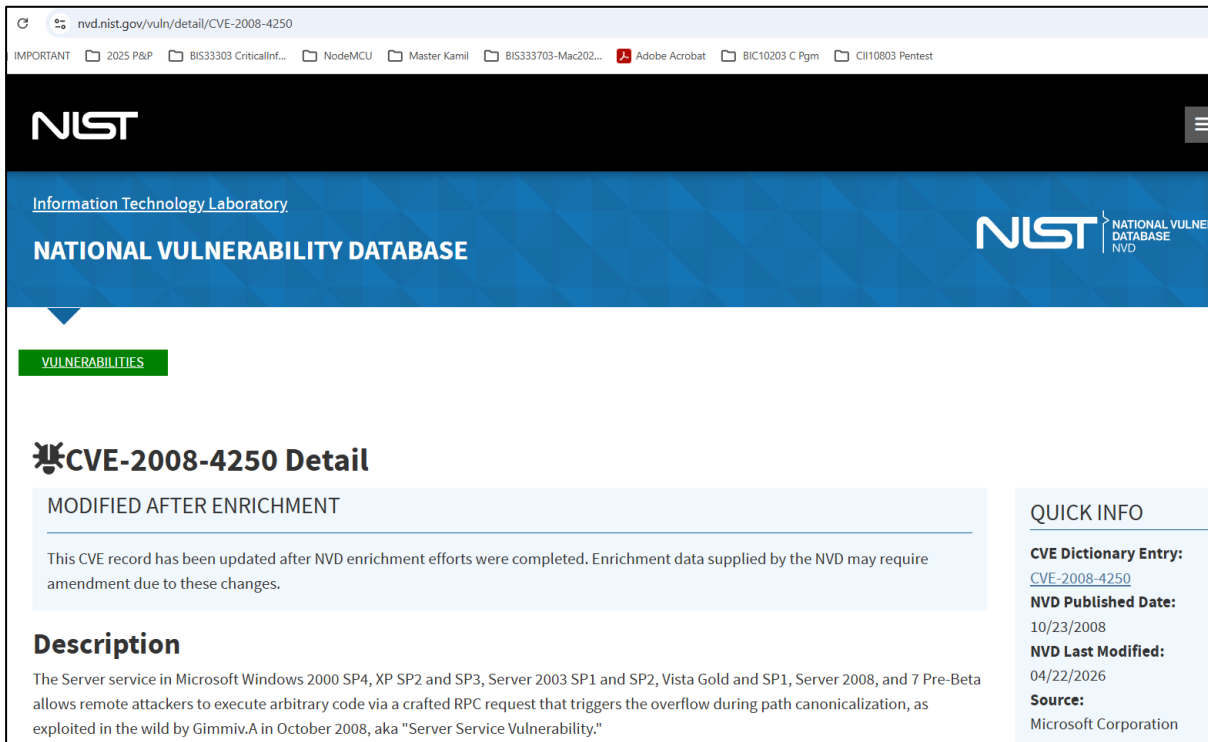


FIGURE A5: CVE id information from FIGURE A4. Find CVE id that can be attacked using Metasploit by referring to *exploit-db.com* or *nvd.nist.gov*.



CVE-2008-4250 Detail

MODIFIED AFTER ENRICHMENT

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Description

The Server service in Microsoft Windows 2000 SP4, XP SP2 and SP3, Server 2003 SP1 and SP2, Vista Gold and SP1, Server 2008, and 7 Pre-Beta allows remote attackers to execute arbitrary code via a crafted RPC request that triggers the overflow during path canonicalization, as exploited in the wild by Gimmiv.A in October 2008, aka "Server Service Vulnerability."

QUICK INFO

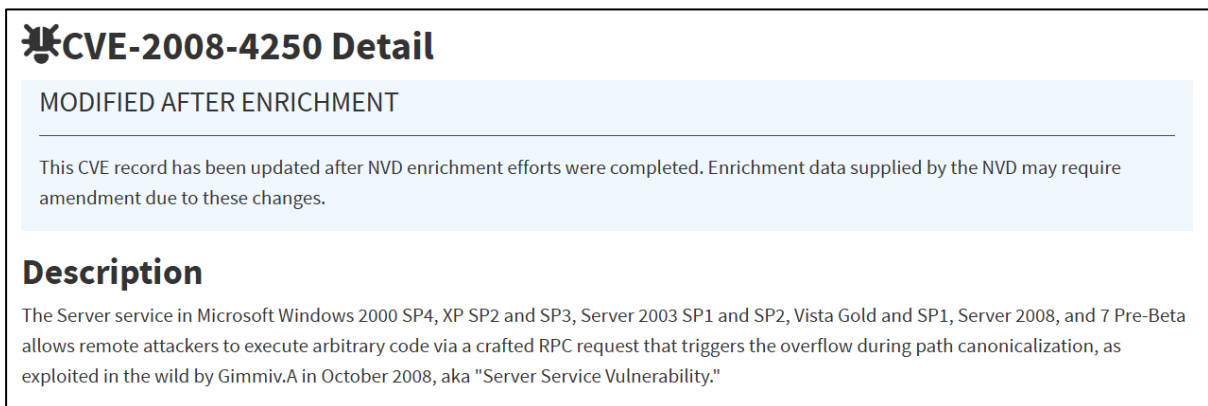
CVE Dictionary Entry:
[CVE-2008-4250](#)

NVD Published Date:
 10/23/2008

NVD Last Modified:
 04/22/2026

Source:
 Microsoft Corporation

FIGURE A6: Show



CVE-2008-4250 Detail

MODIFIED AFTER ENRICHMENT

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Description

The Server service in Microsoft Windows 2000 SP4, XP SP2 and SP3, Server 2003 SP1 and SP2, Vista Gold and SP1, Server 2008, and 7 Pre-Beta allows remote attackers to execute arbitrary code via a crafted RPC request that triggers the overflow during path canonicalization, as exploited in the wild by Gimmiv.A in October 2008, aka "Server Service Vulnerability."

FIGURE A7: Show

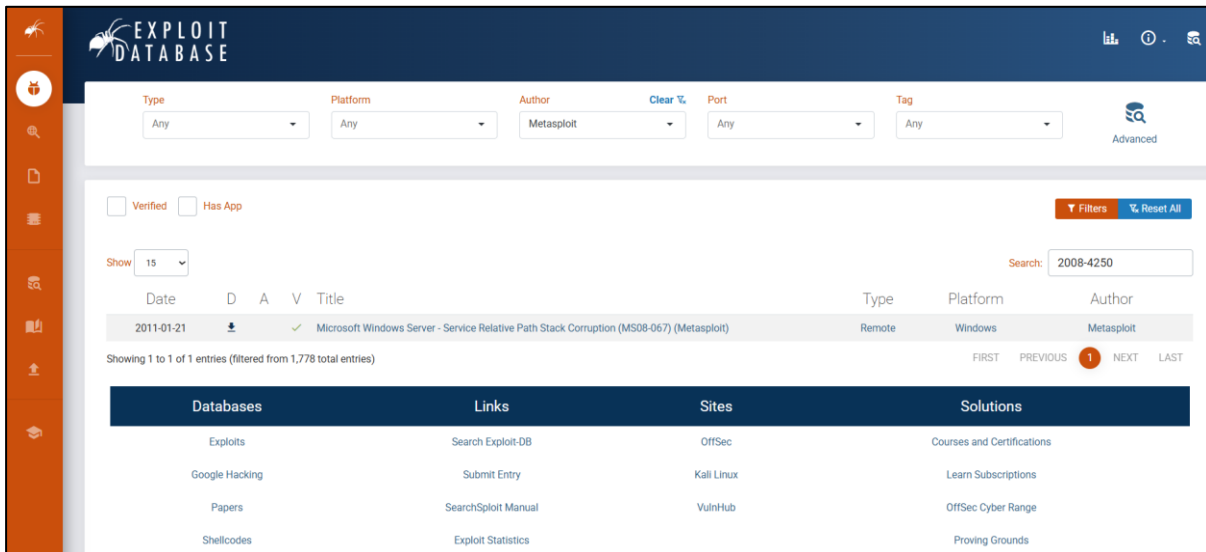


FIGURE A8: Go to exploit-db.com (<https://www.exploit-db.com>) in your web browser. Type '2008-4250' in the Search box, to find **CVE id 2008-4250**, for Windows XP.

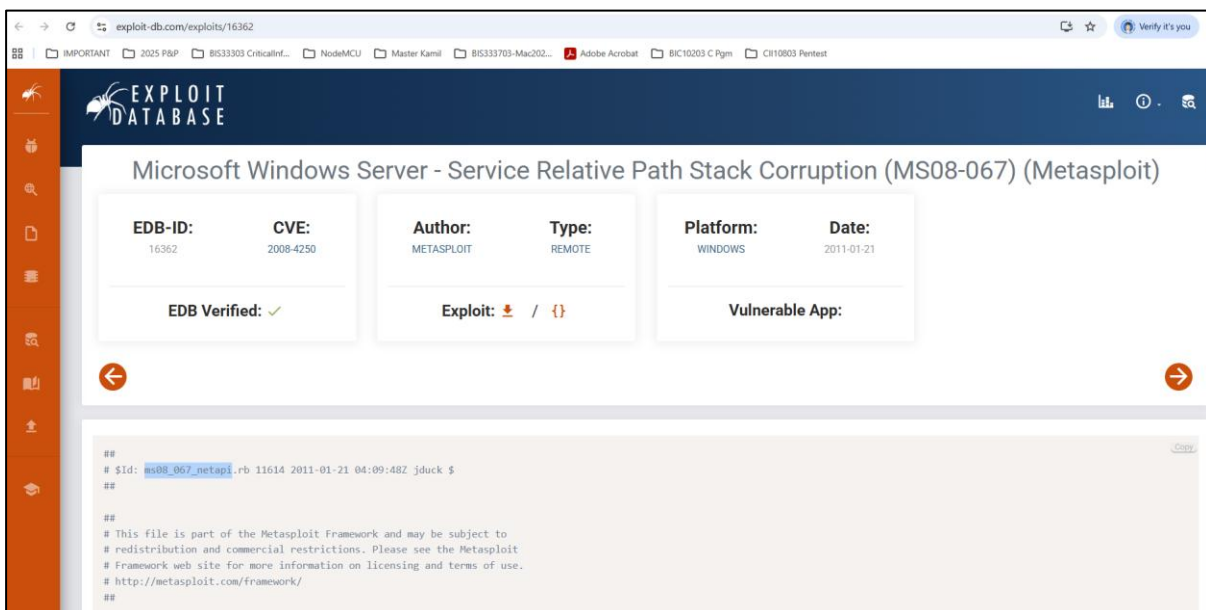


FIGURE A9: Detail for **CVE id 2008-4250** will be shown (<https://www.exploit-db.com/exploits/16362>).